

API Security Risk Analysis Report

1. Introduction

This report presents a security assessment of the JSONPlaceholder public API. The objective is to identify common API security risks, evaluate their impact, and recommend mitigation measures.

2. API Information

API Name: JSONPlaceholder

API Type: REST API

Base URL: <https://jsonplaceholder.typicode.com>

Testing Tool: Postman

3. Testing Methodology

- Accessed public API endpoints using Postman.
- Reviewed authentication requirements.
- Checked for exposed data.
- Assessed rate-limiting behavior.
- Evaluated input validation mechanisms.

4. Findings

Finding 1: Missing Authentication (High)

The endpoint `/users` returned user information without requiring authentication, API keys, or access tokens. Recommendation: Implement API key authentication, OAuth 2.0, or JWT-based access control.

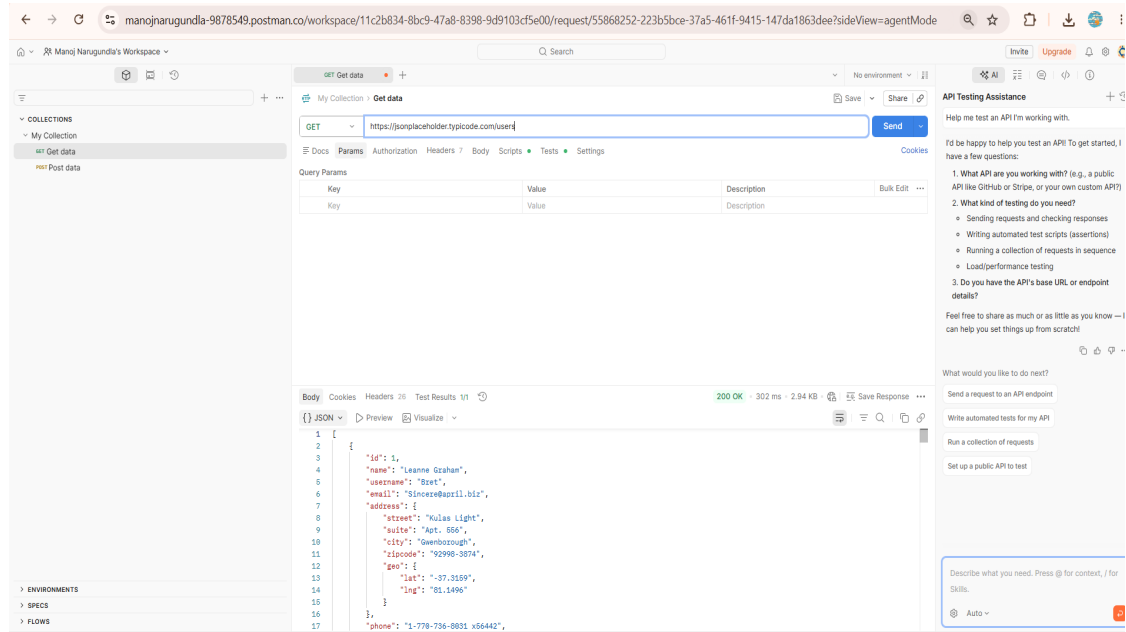


Figure 1: Access to `/users` endpoint without authentication.

Finding 2: Data Exposure (Medium)

Data from API resources is publicly accessible through endpoints. Recommendation: Expose only necessary data and apply access controls.

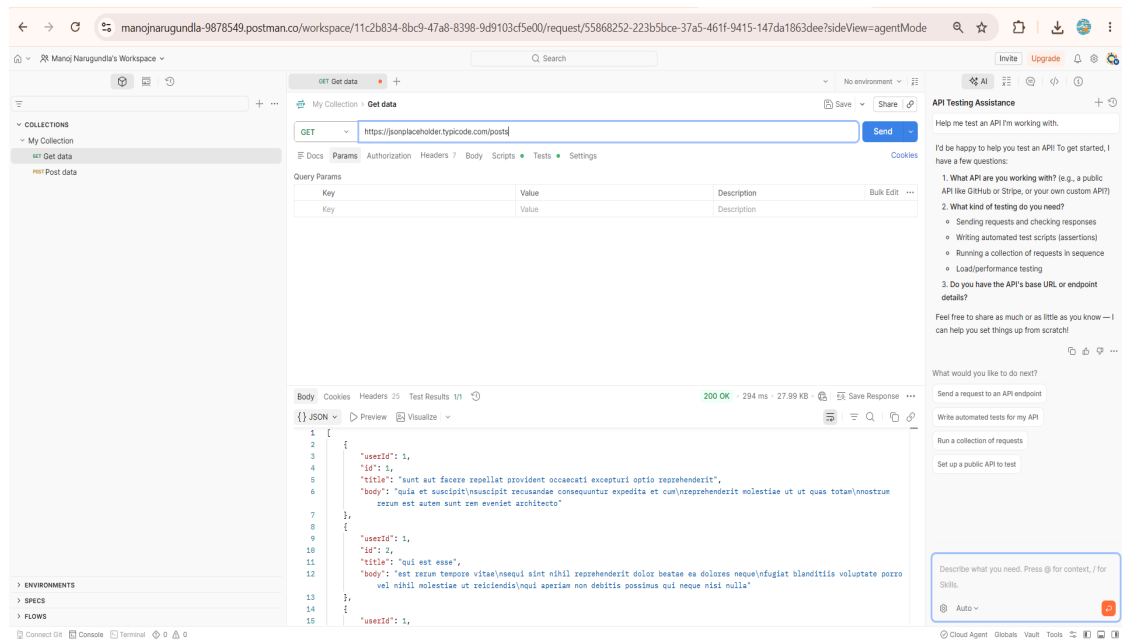


Figure 2: Publicly accessible data returned from /posts endpoint.

Finding 3: No Visible Rate Limiting (Medium)

Requests were accepted successfully without any visible rate-limiting response. Recommendation: Implement request throttling and rate-limiting controls.

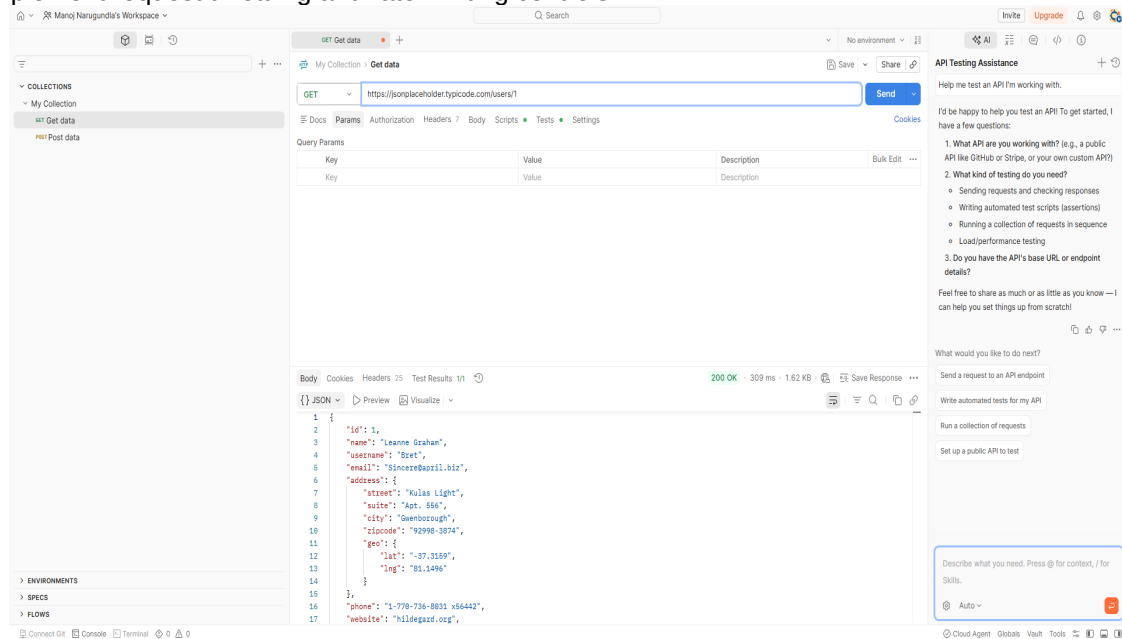


Figure 3: Successful API response indicating absence of visible rate-limiting controls.

5. Conclusion

The assessment identified common security concerns including missing authentication, data exposure risks, and lack of visible rate limiting. Implementing appropriate controls would improve API security.